

USCC Eastern Cyber Camp

Complete Training Workbook

Day 1: Foundations, AI Lab & Bug Hunting | Day 2: Mobile Forensics & FTK Imager

Day 3: Malware Analysis (RedTail) & System Lockdown | Day 4: Linux Forensics & UAC

Investigation

Day 4 Lunch: CIO/Career Panel | Day 5: CTF Competition

Student Brandonn

Program US Cyber Range (USCC) Eastern Cyber Camp 2026

Location Lone Oak, TX

Date June 2026

Certification ISC2 Certified in Cybersecurity (CC)

Classification **NOT FOR DISTRIBUTION — Personal Training Use Only**

Table of Contents

Section 1 — Program Overview

- 1.1 About the Eastern Cyber Camp
- 1.2 Real Camp Schedule
- 1.3 How to Use This Workbook

Section 2 — Day 1: Foundations, AI Lab & Bug Hunting

- 2.1 Morning — Program Kickoff & AI Lab
 - AI in Cybersecurity · The Anthropic/China/Claude Incident · YARA Rule Basics
- 2.2 Afternoon — Bug Hunting & Exploit Analysis
 - OWASP Top 10 · SQL Injection Payloads · Web Recon Cheat Sheet · Bug Hunting Tips
- 2.3 Day 1 Reflection Questions

Section 3 — Day 2: Mobile Forensics

3.1 Morning — Mobile Forensics Introduction

Acquisition Types · Write Blockers · Faraday Bags · Chain of Custody

3.2 Free Mobile Forensics Tools · ADB Commands · Critical Android Paths

3.3 iOS Backup Forensics · EXIF Metadata Analysis · Mobile Artifact Quick Reference

3.4 Afternoon — FTK Imager Lab & Ethics Panel

3.5 Day 2 Reflection Questions

Section 4 — Day 3: Malware Analysis & System Lockdown

4.1 Morning — The RedTail BitMiner Incident

Background · IOCs · Static Analysis · Dynamic Analysis · RedTail-Specific Commands

4.2 The Full 6-Step Malware Analysis Workflow

4.3 Afternoon — System Lockdown & Cloud CTF Demo

4.4 Day 3 Reflection Questions

Section 5 — Day 4 (AM): Linux Forensics & UAC Investigation

5.1 Morning — Linux Forensics

System Enumeration · User Investigation · Log Analysis · File System · Processes · Persistence

5.2 The 7-Step UAC Investigation Workflow

Step 1 Preserve → Step 2 Scope → Step 3 Users → Step 4 Trace → Step 5 Persistence → Step 6 Network → Step 7 Report

5.3 Day 4 Reflection Questions

Section 6 — Day 4 Lunch: CIO / Career Panel

6.1 Bob Costello — Key Quotes & Career Lessons

6.2 Balaji Subramaniam — Key Quotes & Career Lessons

6.3 Lou McCormack — Key Quotes

6.4 Career Panel Consolidated Takeaways

Section 7 — Tools Quick-Reference Guide

7.1 Forensics & Acquisition Tools

7.2 Malware Analysis Tools

7.3 System Security, Hardening & Bug Hunting Tools

Section 8 — CTF Preparation Guide

- 8.1 CTF Categories & Strategy (Forensics, Crypto, Web, OSINT, RE)
- 8.2 CTF Mindset Rules & Practice Platforms

Section 9 — Glossary of Key Terms

Section 10 — Action Items & Next Steps

Section 1

Program Overview

1.1 About the Eastern Cyber Camp

The Eastern Cyber Camp, hosted through the US Cyber Range (USCC), is an intensive hands-on cybersecurity training program designed to bridge the gap between foundational knowledge and practical field readiness. The program combines structured instruction, live lab exercises, and competitive CTF challenges to immerse participants in real-world cybersecurity scenarios. Participants engage with technologies and workflows used daily by cybersecurity analysts, digital forensics investigators, and incident responders.

1.2 Real Camp Schedule

Day	Focus Areas
Day 1 (Mon)	Foundations, AI Lab, and Bug Hunting
Day 2 (Tue)	Mobile Forensics + FTK Imager Lab + Ethics Panel
Day 3 (Wed)	Malware Analysis (RedTail BitMiner Incident) + System Lockdown + Cloud CTF Demo
Day 4 AM (Thu)	Linux Forensics + UAC Investigation (7-Step Workflow)
Day 4 Lunch (Thu)	CIO/Career Panel — McCormack, Costello, Balaji
Day 5	CTF Competition

1.3 How to Use This Workbook

- Read each day's section before reviewing your notes
- Commands are in code-block format — copy, practice, memorize
- Reflection questions appear at the end of each day
- The Tools Reference and Glossary are in Sections 7 and 9
- Action items are in Section 10 — check them off as you go

Section 2 — Day 1 (Monday)

Foundations, AI Lab & Bug Hunting

2.1 MORNING SESSION — PROGRAM KICKOFF & AI LAB

Session Goal: Understand how AI tools are being used in cybersecurity offense and defense, and how to use AI responsibly as a practitioner.

KEY CONCEPTS COVERED

- Introduction to the US Cyber Range and camp expectations
- What is AI in the context of cybersecurity?
- How threat actors exploit AI: social engineering at scale, AI-generated phishing, adversarial prompting
- AI is a tool, not a replacement — coders are still needed; AI changes what coding looks like, not whether it exists
- The best AI prompters are not always who you expect — Bob Costello noted that the best prompter on his team had a classics/Latin degree, not a CS degree

REAL-WORLD INCIDENT — THE ANTHROPIC / CHINA / CLAUDE CASE

China tricked an AI model into role-playing a character in order to get it to help attack a system — a documented case of agentic AI misuse. Bob Costello directly referenced this at the camp panel: *"I do find some of the things that some companies publish helpful, like Anthropic's report... It was like 5 or 7 pages on how China had used Claude to attack a system by tricking it into role-playing. I got a lot out of those 8 pages, and it wasn't so technical."*

BOB COSTELLO ON "AI SLOP"

"Writing is not dead. I can still tell when someone delivers me AI slop, either in an email or in a work product. I would rather see a typo, but know that I'm talking to the person, than

talking to Claude." — **Robert "Bob" Costello, ex-CISA CIO**

AI LAB EXERCISES

- Hands-on prompting: crafting precise queries vs. vague queries
- Identifying AI-generated output vs. human output
- Reviewing how YARA rules and Sigma detection signatures can be partially generated with AI assistance
- Discussion: accountability gap — who is responsible when AI makes a mistake in a security context?

YARA RULE BASICS (INTRODUCED IN AI LAB)

```
rule SuspiciousEncodedPowerShell {  
  
    meta:  
  
        author      = "Brandonn"  
  
        description = "Detects encoded PowerShell execution"  
  
        camp        = "USCC Eastern 2026"  
  
    strings:  
  
        $s1 = "-EncodedCommand" nocase  
  
        $s2 = "-enc " nocase  
  
        $s3 = "IEX(" nocase  
  
        $s4 = "Invoke-Expression" nocase  
  
    condition:  
  
        any of them  
  
}
```

2.2 AFTERNOON SESSION — BUG HUNTING & EXPLOIT ANALYSIS

Session Goal: Apply an offensive mindset to find vulnerabilities in web applications before malicious actors do. Understand the OWASP Top 10 and practice hands-on exploit analysis.

BUG HUNTING FUNDAMENTALS

- Bug bounty programs: companies pay researchers to find and responsibly disclose vulnerabilities
- Responsible disclosure: **always get written permission** before testing any system — unauthorized testing is illegal
- The difference between a vulnerability (a flaw) and an exploit (code/technique that weaponizes it)
- General methodology: Reconnaissance → Scanning → Exploitation → Post-Exploitation → Reporting

OWASP TOP 10 (2021) — COVERED IN SESSION

Rank	Name	Key Example
A01	Broken Access Control	Accessing admin pages without authorization
A02	Cryptographic Failures	Storing passwords in plaintext
A03	Injection	SQL injection via unsanitized input fields
A04	Insecure Design	No rate limiting on login attempts
A05	Security Misconfiguration	Default credentials left unchanged
A06	Vulnerable Components	Outdated library with known CVE
A07	Auth & Session Failures	Session token exposed in URL
A08	Software Data Integrity	Unsigned software updates
A09	Logging/Monitoring Failures	No alerting on repeated failed logins
A10	SSRF	Server fetches attacker-controlled URL

SQL INJECTION LAB PAYLOADS

```
-- Basic test for injection vulnerability
```

```
' OR '1'='1
```

```
' OR 1=1 --
```

```
" OR "1"="1
```

```
'; DROP TABLE users; --
```

```
-- Extract database version

' UNION SELECT @@version, NULL --

-- Extract table names

' UNION SELECT table_name, NULL FROM information_schema.tables --
```

WEB RECON CHEAT SHEET

```
# Check for hidden paths and files

gobuster dir -u http://target.com -w /usr/share/wordlists/dirbuster/common.txt

dirb http://target.com

# Quick vulnerability scan

nikto -h http://target.com

# Always check these first:

curl http://target.com/robots.txt

curl http://target.com/sitemap.xml

# Subdomain enumeration

subfinder -d target.com

# Parameter fuzzing

ffuf -u http://target.com/page?id=FUZZ -w wordlist.txt
```

BUG HUNTING TIPS FROM DAY 1

- Test every input field: login forms, search boxes, file uploads, URL parameters, cookies
- Look for verbose error messages — they reveal database type, software versions, and stack traces
- Check for IDOR: change numeric IDs in API calls (e.g., `/user/1001` → `/user/1002`)
- Inspect page source and JavaScript files before attacking
- `robots.txt` and `sitemap.xml` often reveal hidden admin paths

2.3 DAY 1 REFLECTION QUESTIONS

1. What is the difference between a vulnerability and an exploit?
2. Name three things you would check first when approaching a new web target.
3. Why is it dangerous for an AI system to be given unrestricted tool-use capabilities without human oversight?
4. What OWASP vulnerability allows an attacker to access another user's records by changing an ID in a URL?

Section 3 — Day 2 (Tuesday)

Mobile Forensics

3.1 MORNING SESSION — MOBILE FORENSICS INTRODUCTION

Session Goal: Understand how digital evidence is acquired from mobile devices, what data is accessible, and how to legally and ethically handle mobile evidence.

WHY MOBILE FORENSICS MATTERS

- Mobile devices contain call logs, SMS, app data, GPS history, photos with metadata, email, and cloud sync artifacts
- In many investigations, a suspect's phone is the most valuable evidence source
- Mobile data is often synced to cloud services — evidence may persist even after a device factory reset

ACQUISITION TYPES — LEAST TO MOST INVASIVE

Type	Description	Access Level	Notes
Logical	Backup-based extraction	Files and apps	Fastest; misses deleted data
File System	Direct file system dump	Full file system	Requires unlocking or exploit
Physical	Bit-for-bit NAND flash copy	Everything including deleted	Most complete; hardware tools required
Chip-Off	Physical chip removal + read	Complete raw storage	Destructive; last resort

KEY CONCEPTS

- **Write blocker:** hardware or software device that prevents any write operations to evidence — mandatory for forensic acquisition
- **Hash verification:** SHA256 or MD5 hash before and after acquisition — if hashes match, evidence is intact
- **Chain of custody:** document every person who touched the device and every step taken
- **Faraday bag/cage:** blocks all wireless signals to prevent remote wipe during acquisition

3.2 FREE MOBILE FORENSICS TOOLS & ADB COMMANDS

FREE MOBILE FORENSICS TOOLS (COVERED IN CAMP)

Tool	Platform	Purpose
ADB (Android Debug Bridge)	Android	Access device file system, pull app data
FTK Imager	Windows	Disk and mobile image acquisition — free from Exterro
Autopsy	Windows/ Linux	Open-source forensic analysis GUI
Magnet AXIOM	Windows	Commercial mobile + cloud forensics
Cellebrite UFED	Windows	Industry standard physical extraction

iBackupBot	Windows/Mac	Parse iOS backup files
exiftool	All	Extract photo/file metadata including GPS
Oxygen Forensics	Windows	Multi-platform mobile extraction

ANDROID FORENSICS — ADB COMMANDS

```
# Verify device is connected

adb devices

# Open interactive shell on device

adb shell

# Pull specific app data directory

adb pull /data/data/com.whatsapp/ ./whatsapp_data/

# Pull all app data (requires root)

adb pull /data/data/ ./all_apps/

# Full logical backup

adb backup -apk -all -f full_backup.ab

# List installed packages

adb shell dumpsys package | grep "Package \["
```

```
# Device info

adb shell getprop ro.product.model

adb shell getprop ro.build.version.release


# Battery and usage stats

adb shell dumpsys battery

adb shell dumpsys usagestats
```

CRITICAL ANDROID EVIDENCE PATHS

```
/data/data/<package>/databases/ → SQLite databases (messages, contacts, history)

/data/data/<package>/shared_prefs/ → App settings and credentials (XML)

/sdcard/DCIM/ → Camera photos and videos

/sdcard/Downloads/ → Downloaded files

/data/system/packages.xml → Installed package registry

/data/misc/wifi/WifiConfigStore.xml → Known Wi-Fi networks + passwords (root)

/data/data/com.android.providers.telephony/databases/mmssms.db → SMS/MMS database

/data/data/com.android.contacts/databases/contacts2.db → Contacts database
```

3.3 IOS FORENSICS, EXIF ANALYSIS & MOBILE ARTIFACT QUICK REFERENCE

IOS BACKUP FORENSICS

```
Backup location (Mac): ~/Library/Application Support/MobileSync/Backup/

Backup location (Win): C:\Users\<user>\AppData\Roaming\Apple Computer\MobileSync\Backup\
```

Key iOS artifact databases:

sms.db → Text messages and iMessages

call_history.db → Call logs (incoming, outgoing, missed)

AddressBook.sqlitedb → Contacts

Maps.sqlite → Location search history

SafariHistory.db → Browser history

photoData.db → Photo library metadata

Tool: iBackupBot – parse and export iOS backup contents without iTunes

EXIF METADATA ANALYSIS

Full EXIF dump from a photo

exiftool photo.jpg

Extract only GPS coordinates

exiftool -GPS* photo.jpg

Export metadata from entire directory to CSV

exiftool -csv *.jpg > photo_metadata.csv

Find GPS from multiple photos at once

exiftool -r -GPS* /path/to/photos/

Remove all metadata (for privacy)

MOBILE KEY ARTIFACTS QUICK REFERENCE

Artifact	Android Location	iOS Location
SMS/MMS	mmssms.db	sms.db
Call Logs	contacts2.db	call_history.db
Contacts	contacts2.db	AddressBook.sqlitedb
Browser History	browser2.db / Chrome: History	SafariHistory.db
App Data	/data/data/<package>/	App Containers
GPS History	Google Timeline / EXIF	Apple Maps / EXIF
Wi-Fi History	WifiConfigStore.xml	com.apple.wifi.plist

3.4 AFTERNOON SESSION — FTK IMAGER LAB & ETHICS PANEL

FTK Imager is a **free** forensic imaging tool from Extterro used industry-wide to acquire, preview, and verify digital evidence.

FTK IMAGER LAB — STEP-BY-STEP WORKFLOW

1. **Launch FTK Imager** → File → Create Disk Image
2. **Select Source:** Physical Drive (full disk) or Logical Drive (partition)
3. **Choose Image Format:**
 - **E01 (EnCase)** — industry standard; includes case metadata and built-in hash verification
 - **DD/RAW** — bit-for-bit copy; no metadata wrapper; compatible with all tools
 - **AFF** — Advanced Forensic Format (less common)
4. **Fill Case Information:** Case number, examiner name (Brandonn), description, evidence number
5. **Set Destination:** Choose output path and filename
6. **Fragmentation:** Set fragment size (0 = no fragmentation; use 1500 MB if storage limits apply)
7. **Verify Images After Creation:** FTK computes MD5 and SHA1 automatically — record both hashes
8. **Review Summary:** Confirm hashes match; save summary report

FTK IMAGER — KEY FEATURES USED IN LAB

- **Image Mounting:** Mount .E01 or .DD files read-only for analysis without modifying original
- **Evidence Tree:** Browse file system including deleted files and unallocated space
- **Export Files:** Extract individual files from image for further analysis
- **Custom Content Image:** Create image of specific folders or files only

ETHICS PANEL — KEY POINTS

- All forensic work requires proper legal authority: search warrant, consent, or corporate policy
- Handling personal data (photos, messages, medical, financial) requires discretion and professionalism
- Evidence must be documented, hashed, and stored securely — tampering is a federal crime
- Reporting findings accurately regardless of which side benefits is a professional obligation

3.5 DAY 2 REFLECTION QUESTIONS

1. What is the difference between a logical and a physical mobile extraction?
2. Why must you hash an image before and after acquisition?
3. What does a Faraday bag do and when should it be used?
4. Name the SQLite database that stores Android SMS messages.
5. What FTK Imager format includes built-in case metadata and hash verification?

Section 4 — Day 3 (Wednesday)

Malware Analysis & System Lockdown

4.1 MORNING SESSION — THE REDTAIL BITMINER INCIDENT

Session Goal: Work through a real-world malware incident — the RedTail cryptominer — using a structured malware analysis workflow.

THE REDTAIL BITMINER — BACKGROUND

RedTail is a sophisticated cryptomining malware that specifically targeted Linux servers. It

was deployed by threat actors exploiting known vulnerabilities to gain initial access, then installing the miner to generate cryptocurrency using victim compute resources. Key characteristics:

- Targeted Linux environments (servers, cloud instances)
- Exploited PAN-OS vulnerability **CVE-2024-3400** (Palo Alto firewall) for initial access in some variants
- Used process hiding techniques to evade detection
- Consumed 90–100% CPU to mine Monero (XMR)
- Established persistence through cron jobs and modified startup scripts
- Used obfuscated shell scripts as droppers

REDTAIL INDICATORS OF COMPROMISE (IOCS)

Process names: .redtail, kthread, [kworker/u:0], or randomized names

File locations: /tmp/.redtail, /dev/shm/[random], /var/tmp/[random]

Network: Connections to mining pools (pool.hashvault.pro, xmrbpool.eu)

CPU behavior: Sustained 90–100% CPU usage by unknown process

Persistence: Cron job executing hidden script; modified /etc/rc.local

File perms: World-writable executables; SUID binaries in /tmp

PHASE 1 — STATIC ANALYSIS (DO NOT EXECUTE THE SAMPLE)

Step 1: Identify and hash the file

file suspicious_binary

sha256sum suspicious_binary # Submit hash to VirusTotal – never upload PII-containing samples

md5sum suspicious_binary

Step 2: Extract readable strings

strings suspicious_binary

strings -e l suspicious_binary # Unicode strings

```
strings suspicious_binary | grep -iE "http|ftp|cmd|bash|cron|/tmp|exec|wget|curl|  
chmod"
```

```
# Step 3: Examine ELF/PE structure
```

```
readelf -h suspicious_binary      # ELF header (Linux binaries)
```

```
readelf -d suspicious_binary      # Dynamic dependencies
```

```
objdump -d suspicious_binary      # Disassemble
```

```
file suspicious_binary            # Confirm architecture and type
```

```
# Step 4: Look for obfuscation
```

```
xxd suspicious_binary | head -30 # Check hex for packed/encrypted content
```

```
# High entropy = likely packed or encrypted
```

PHASE 2 — DYNAMIC ANALYSIS (ISOLATED VM ONLY — NEVER ON LIVE NETWORK)

WARNING

Always analyze in an ISOLATED VM with no network access to production systems. Never execute malware on a host machine or connected to a live network.

```
# Before executing the sample, set up monitoring:
```

```
Process Monitor (ProcMon) → File system, registry, process tree activity
```

```
Wireshark → Capture all network traffic
```

```
Regshot → Take registry snapshot BEFORE execution
```

```
FakeNet-NG → Simulate network to capture C2 communications
```

```
Sysmon (Windows) → Detailed event logging
```

```
# Execute sample. Observe and document:
```



```
→ Files created, modified, or deleted

→ Registry keys added (esp. Run keys for persistence)

→ Network connections: IP, port, protocol, beacon interval

→ Child processes spawned

→ CPU/memory usage spike

→ Mutex objects created (anti-double-execution indicator)

# After execution:

→ Take second Regshot → compare before/after for registry changes

→ Export ProcMon log and filter for malware PID

→ Review Wireshark capture for C2 pattern
```

REDTAIL-SPECIFIC INVESTIGATION COMMANDS

```
# Check CPU usage anomaly

top -b -n 1 | head -20

ps aux --sort=-%cpu | head -10

# Find the hidden process

ps aux | grep -v grep | grep -E "\.(redtail|tmp|shm)"

ls -la /tmp/ /dev/shm/ /var/tmp/ # Hidden files in common staging areas

# Check cron persistence

crontab -l

cat /etc/crontab
```

```
ls -la /etc/cron.*
```

```
# Network connections to mining pools
```

```
ss -tulnp | grep -v "127.0.0.1"
```

```
netstat -tulnp
```

```
lsof -i | grep -v "127.0.0.1"
```

4.2 THE FULL 6-STEP MALWARE ANALYSIS WORKFLOW

STEP 1

Acquire and Preserve

Obtain the malware sample safely (from sandbox, honeypot, or trusted repo like

MalwareBazaar). Hash the original with `sha256sum` — this is your evidence integrity

anchor. Never work on the original; make a working copy. Document filename,

origin, date/time received, and chain of custody.

STEP 2

Static Analysis (no execution)

File type identification (`file`, magic bytes). String extraction (`strings` — look for

URLs, IPs, commands, error messages, registry paths). PE/ELF header analysis:

imports, exports, section names, compiler artifacts. VirusTotal lookup by SHA256

hash. Apply known YARA signatures.

STEP 3

Dynamic Analysis (sandbox or isolated VM)

Set up monitoring tools BEFORE executing. Execute in controlled environment.

Document all behavior: files, registry, network, processes. Capture network traffic

with Wireshark.

STEP 4

Memory Analysis (post-execution)

Dump process memory — look for unpacked/decrypted code in RAM. Use Volatility:

`windows.malfind` for injected regions, `windows.cmdline` for arguments passed to

processes.

STEP 5

Reporting

Produce an IOC list: all IPs, domains, file hashes, registry keys, and process names.

Map behaviors to MITRE ATT&CK tactics and techniques. Write an executive

summary and a technical appendix.

STEP 6

Detection & Response

Write a YARA rule for the identified strings/patterns. Write a Sigma rule for SIEM

detection. Implement firewall blocks for C2 IPs/domains. Patch the exploited

vulnerability.

4.3 AFTERNOON — SYSTEM LOCKDOWN & CLOUD CTF DEMO

SYSTEM LOCKDOWN — HARDENING CHECKLIST

```
# Disable unnecessary services

systemctl disable <service>

systemctl stop <service>


# Close unused ports

ufw enable

ufw deny incoming

ufw allow 22/tcp    # SSH only if needed

ufw allow 443/tcp


# Remove unauthorized users

userdel -r suspicious_user
```

```
passwd -l compromised_account # Lock account without deleting

# Find and remove persistence

crontab -r # Remove current user's crons

cat /etc/crontab # Verify system crons

rm /etc/init.d/malicious_service # Remove startup script

# Remove dropped malware

find /tmp /dev/shm /var/tmp -name ".*" -delete # Hidden files in staging areas

find / -name ".redtail" -delete

# Update and patch

apt update && apt upgrade -y

# Audit SUID binaries

find / -perm /4000 2>/dev/null | tee suid_list.txt
```

CLOUD CTF DEMO — KEY TAKEAWAYS

- CTF challenges mirror real-world scenarios in a gamified format
- Cloud-hosted CTFs allow browser-based access without local setup
- Flag format at USCC: standard `CTF{...}` or challenge-specific format
- Common cloud CTF categories: web exploits, forensics, crypto, OSINT

4.4 DAY 3 REFLECTION QUESTIONS

1. What technique does RedTail use to stay hidden on a Linux system?
2. Name three things you should set up BEFORE executing malware in a sandbox.
3. What command finds files that were modified in the last 24 hours?

4. What is the purpose of FakeNet-NG in dynamic malware analysis?
5. What MITRE ATT&CK tactic does adding a cron job represent?

Section 5 — Day 4 AM (Thursday)

Linux Forensics & UAC Investigation

5.1 MORNING SESSION — LINUX FORENSICS

Session Goal: Investigate a compromised Linux system using command-line forensics tools. Identify attacker activity across logs, processes, users, files, and network connections.

THE LINUX FORENSICS MINDSET

- Work from the outside in: start with what is running NOW, then work backwards through history
- Everything leaves a trace — processes, network connections, login events, file changes
- Volatile data first: RAM and running processes disappear on reboot
- Non-volatile second: disk files, logs, and history persist across reboots

SYSTEM ENUMERATION — START HERE

```
uname -a # OS, kernel version, architecture

hostname # Machine name

date # Current time (compare to log timestamps)

uptime # How long since last boot

whoami && id # Current user and group memberships

cat /etc/os-release # Detailed OS information
```

USER ACCOUNT INVESTIGATION

```
cat /etc/passwd # All accounts: username:x:UID:GID:comment:home:shell
```

```
cat /etc/shadow          # Hashed passwords (requires root)

cat /etc/group           # Group memberships

last                    # Login history (reads /var/log/wtmp)

lastlog                 # Most recent login per user

w                      # Who is currently logged in + what they are doing

who                    # Currently logged-in users
```

WHAT TO LOOK FOR IN /ETC/PASSWD

- Accounts with UID 0 other than root — instant red flag for privilege escalation
- Accounts with no shell (/bin/false or /sbin/nologin) that have login history
- Recently created accounts (check `ls -la /home/`)
- Accounts with unusual home directories (e.g., /tmp, /dev/shm)

LOG INVESTIGATION

```
# Authentication events

cat /var/log/auth.log          # Ubuntu/Debian

cat /var/log/secure            # RHEL/CentOS

grep "Failed password" /var/log/auth.log # Failed SSH attempts

grep "Accepted" /var/log/auth.log      # Successful SSH logins

grep "sudo" /var/log/auth.log          # Sudo usage


# System events

cat /var/log/syslog            # General system log

journalctl -xe                 # Systemd journal (recent events)

journalctl -u sshd --since "2026-06-08" # SSH service events since a date

journalctl -u cron              # Cron execution log
```

```
# Application logs
```

```
ls /var/log/ # All available logs
```

```
cat /var/log/kern.log # Kernel-level events
```

```
cat /var/log/dpkg.log # Package install/remove history (Ubuntu)
```

FILE SYSTEM INVESTIGATION

```
# Recently modified files (key for finding dropped malware)
```

```
find / -mtime -1 2>/dev/null # Modified in last 24 hours
```

```
find / -mtime -7 2>/dev/null # Modified in last 7 days
```

```
find /tmp /dev/shm /var/tmp -ls # Common attacker staging areas
```

```
# Hidden files (dot files)
```

```
ls -la /home/*/ # All user home directories
```

```
ls -la /root/ # Root's home directory
```

```
find / -name ".*" -ls 2>/dev/null # All hidden files system-wide
```

```
# File identification
```

```
file suspicious_file # True file type by magic bytes
```

```
strings suspicious_file | head -50 # Readable strings
```

```
xxd suspicious_file | head -20 # Hex dump
```

```
stat filename # Access, modify, change timestamps
```

```
# SUID binaries (privilege escalation risk)
```



```
find / -perm /4000 2>/dev/null # All SUID files
```

```
find / -perm /2000 2>/dev/null # All SGID files
```

PROCESS AND NETWORK STATE

```
# Running processes
```

```
ps aux # All processes with user and resource info
```

```
ps aux | sort -k3 -rn | head -10 # Top CPU consumers
```

```
ps auxf # Process tree (forest view)
```

```
# Network state
```

```
ss -tulnp # All open ports + listening services (modern)
```

```
netstat -tulnp # Same (legacy, still widely used)
```

```
lsof -i # All open network connections + process name
```

```
lsof -i :22 # Who is connected to SSH port
```

```
lsof -p PID # All files and connections for a specific PID
```

SHELL HISTORY AND COMMAND ARTIFACTS

```
cat ~/.bash_history # Current user bash history
```

```
cat /home/*.bash_history # All users' bash history (root required)
```

```
cat /root/.bash_history # Root's command history
```

```
history # Current session history
```

```
# Shell config files (may contain malicious commands)
```

```
cat ~/.bashrc
```

```
cat ~/.bash_profile
```

```
cat ~/.profile
```

```
cat /etc/profile
```

```
cat /etc/bash.bashrc
```

PERSISTENCE MECHANISM LOCATIONS — CHECK ALL OF THESE

```
# Cron jobs
```

```
crontab -l # Current user
```

```
crontab -l -u username # Specific user
```

```
cat /etc/crontab # System-wide cron
```

```
ls -la /etc/cron.{d,daily,hourly,weekly,monthly}/
```

```
# Systemd services (most common modern persistence)
```

```
systemctl list-units --type=service --all
```

```
cat /etc/systemd/system/suspicious.service
```

```
ls -la /etc/systemd/system/
```

```
# Legacy startup
```

```
cat /etc/rc.local
```

```
ls -la /etc/init.d/
```

```
ls -la /etc/rc*.d/
```

```
# GUI autostart (desktop environments)
```

```
ls ~/.config/autostart/
```

```
ls /etc/xdg/autostart/
```

5.2 THE 7-STEP UAC INVESTIGATION WORKFLOW

WHAT IS UAC INVESTIGATION?

Unauthorized Access and Compromise (UAC) investigation is the structured process of determining: **who** accessed a system without authorization, **what** they did, **how** they got in, **when** it happened, and **what** data or systems were affected.

STEP 1

Preserve and Document

Take a snapshot or image before touching anything. Record: system name, IP

address, date/time, who reported the incident. Hash all evidence. Document every

command you run and every file you open. Work on a COPY — never modify original

evidence.

```
# Hash the disk image
```

```
sha256sum disk.img | tee disk.sha256
```

```
# Capture volatile state before any shutdown
```

```
ps aux > volatile_processes.txt
```

```
ss -tulnp > volatile_netstat.txt
```

```
last > volatile_logins.txt
```

STEP 2

Identify the Scope

What system(s) are involved — single machine or lateral movement? What time

window does the incident span? What data, services, or accounts may be affected?

Confirm the system's role: web server? database? domain controller?

```
hostname; uname -a; date; uptime
```

```
cat /etc/hosts # Network connections and hostname mappings
```

```
ip addr; ip route # Network interfaces and routing
```

STEP 3

Investigate Users and Logins

Who has accounts on this system? Who logged in during the incident window? Were

any new accounts created? Were any accounts compromised?

```
cat /etc/passwd | awk -F: '$3 == 0 {print}'      # UID 0 accounts (should ONLY
```

```
be root)
```

```
last | head -30                                # Recent logins
```

```
grep "useradd\\|adduser" /var/log/auth.log      # New account creation
```

```
grep "passwd" /var/log/auth.log                # Password changes
```

STEP 4

Trace Attacker Activity

What commands did the attacker run? What files did they access, create, or modify?

Did they escalate privileges? Did they establish persistence?

```
cat /home/*.bash_history; cat /root/.bash_history  # Command history
```

```
find / -mtime -3 2>/dev/null | grep -v proc      # Files changed in last
```

```
3 days
```

```
grep "sudo\\|su -\\|pkexec" /var/log/auth.log     # Privilege escalation
```

```
attempts
```

```
ls -lat /tmp /dev/shm /var/tmp                  # Attacker staging
```

```
areas
```

STEP 5

Identify Persistence Mechanisms

Did the attacker install anything to survive a reboot? Check every persistence

location.

```
crontab -l; cat /etc/crontab; ls /etc/cron.* # All cron locations
```

```
systemctl list-units --type=service | grep -v "loaded active running"
```

```
cat /etc/rc.local
```

```
find / -newer /etc/passwd -name "*.sh" 2>/dev/null # New shell scripts
```

STEP 6

Examine Network Activity

What outbound connections did the attacker make? Was data exfiltrated? Are there

active C2 connections?

```
ss -tulnp # Current connections
```

```
lsof -i | grep ESTABLISHED # Established
```

```
connections with PIDs
```

```
cat /var/log/syslog | grep -i "connect\|wget\|curl" # Network activity in
```

logs

```
netstat -an | grep ESTABLISHED # All established
```

connections

STEP 7

Document and Report

Write a clear incident timeline: first access → lateral movement → persistence →

exfiltration. Document all IOCs. Determine root cause. Define remediation steps and

recommendations.

INCIDENT REPORT TEMPLATE

Date: _____ Examiner: Brandonn System: _____

1. Executive Summary (2–3 sentences – what happened, when, impact)

2. Timeline of Events

3. Attacker Techniques (MITRE ATT&CK mapping)

4. IOCs (IPs, file hashes, usernames, domains)

5. Root Cause

6. Remediation Steps Taken

7. Recommendations

5.3 DAY 4 REFLECTION QUESTIONS

1. What is the first step of the UAC 7-step investigation workflow and why?
2. What command reveals UID 0 accounts other than root?
3. Name four persistence locations an attacker might use on Linux.
4. What is the difference between `ss` and `netstat`?
5. What does Step 7 (Documentation) include that makes it legally important?

Section 6 — Day 4 Lunch (Thursday)

CIO / Career Panel

Panelists: Luke "Lou" McCormack (Moderator, USCC National Director, ex-DHS CIO) · Robert "Bob" Costello (ex-CISA CIO) · Balaji Subramaniam (Acting CIO, TSA)

Robert "Bob" Costello

Chief Digital & Information Officer, Merlin Group / Merlin Ventures | Ex-CISA CIO (4.5 yrs) | 18

yrs DHS | 9.5 yrs Air Force

ON TAKING JOBS YOU DON'T FEEL QUALIFIED FOR

"Don't not do something because you're afraid of it. If you get offered a job and you don't think that you're qualified, take the job. You'll figure it out. You're just as smart

as everyone else."

— **Bob Costello**

He added that 90 days into Merlin he still has "I feel stupid, I don't understand this"

moments. His advice: **ignore the imposter syndrome.**

ON SOFT SKILLS OVER TECHNICAL SKILLS

"Cyber's a team sport, IT's a team sport... even if you are the smartest person, you have to be able to work across the line."

— **Bob Costello**

He would support a less-technical employee who communicates and collaborates over a brilliant loner.

ON CERTIFICATIONS

"I am never impressed with people that have a string of certs after their name."

— **Bob Costello**

He prefers: *"Can the person or system do the work?"* He favors people with home labs and cloud labs over cert collectors.

ON EARLY CAREER MOVES

- ---

 - Take the project nobody wanted, even low-odds ones — "some of those projects got me in front of Luke"
- ---

 - "I jumped into things, I wasn't afraid of things"

ON AI AND THE ANTHROPIC REPORT

"I do find some of the things that some companies publish helpful, like Anthropic's report that came out a while ago... It was like 5 or 7 pages on how China had used Claude to attack a system by tricking it into role-playing. I got a lot out of those 8 pages, and it wasn't so technical."

— Bob Costello

INTERVIEW TIPS FROM COSTELLO

- ---

 - Research the company AND the interviewer before any interview
- Do **NOT** ask about work-life balance in interviews
- Best question he ever received: **"What makes you love working here, Bob?"**

- ---
- Write down the question the interviewer asks — it buys you time to think

- ---
- **#1 buzzkill: Negativity** — never trash competitors or technology in an

interview

CAREER BACKGROUND HIGHLIGHTS

- ---
- Started on assembly language and machine code in the late 80s/early 90s
- ---
- Built lawful-intercept / FISA interception systems at MCI (later Verizon)
- ---
- Worked with Vint Cerf (father of the internet) early in career
- ---
- Joined Air Force in 1999 "to get some structure" — served 9.5 years
- ---
- Served at ICE, CBP, then CISA as CIO
- ---
- Currently CDIO at Merlin Group — runs FedRAMP accelerator, Merlin Ventures

scouting

Balaji Subramaniam

Acting CIO, TSA | 18 yrs at TSA | 30+ yrs total | Civil/Environmental Engineer → Cyber via IBM

and 9/11

HIS SIGNATURE CAREER PHILOSOPHY

"Speed to impact — not speed to delivery."

— Balaji Subramaniam

TSA's IT used to measure success as delivering software. End users kept saying it

didn't meet their needs. They changed the philosophy: *did it actually impact the*

mission? "You will be remembered because of its impact, not just because you

checked off a box."

ON TRUST IN THE WORKPLACE

"Trust is not built by you simply stating what they want to hear. Trust is built by you giving them the actual reasoning, the risk behind it, telling them how to resolve the risk."

— Balaji Subramaniam

ON RISK-BASED THINKING

"Everything you're taking in life is a risk-based decision... Risk of not doing certain things in 9/11 is what got us here."

— Balaji Subramaniam

Always advise on the risk of **NOT** acting, not just the risk of acting. Always have a *calculated* risk-taking mind.

ON GETTING NOTICED EARLY

"You gotta get noticed... extra hours, making sure things are done."

— Balaji Subramaniam

He personally notices the camper still working at 7 PM — "it sticks in our mind."

ON QUANTUM COMPUTING

"It is not a boogeyman. It's going to start." AI + quantum together will affect

cybersecurity — key management and key cracking. LinkedIn ad trends approximate

what's coming to market: if you're learning frontier AI and quantum now, "that's the

type of people we want to hire."

CAREER BACKGROUND

- Trained civil/environmental engineer — worked on groundwater contamination and Superfund cleanup

- Pivoted to coding and data analysis → IBM supply chain architecture
- 9/11 happened → helped stand up TSA's Secure Flight (now PreCheck)
- Acting CIO at TSA since ~2024/2025

Luke "Lou" McCormack

Moderator | USCC National Director | Ex-DHS CIO

"I guarantee you every single one of you is twice as good as you think you are. I'm 100% convinced of that."

— Lou McCormack

"Fake it till you make it is OK. You get out there and you start swimming... next thing you know you wake up one day and say I'm not faking anymore, I'm flying this plane."

— Lou McCormack

He committed to sharing both panelists' contact information with all students.

6.4 Career Panel — Consolidated Takeaways

Theme	Costello's View	Balaji's View	McCormack's View
First job	Take what gets your foot in; show hunger	Get noticed through extra effort	Even menial work is a stage — be a savage
Certifications	Practical over collection; likes home labs	Stay current; LinkedIn trends = what's hiring	"Geeks that can speak"

AI	Use it, don't let it replace your voice	Quantum+AI convergence is real and coming	Accountability and trust gaps are the real issue
Trust	Manage your boss; no AI slop	Tell the real risk, not what they want to hear	Share contact info; be a connector
Final words	Don't go it alone — find a mentor	Don't short-sell yourself; evolve	You are twice as good as you think

Section 7 — Tools Quick-Reference Guide

7.1 Forensics & Acquisition Tools

Tool	Platform	Purpose	Cost
FTK Imager	Windows	Disk/mobile image acquisition, preview	Free
Autopsy	Win/Linux	Full forensic analysis GUI (disk, mobile, email)	Free
Sleuth Kit	Linux	CLI forensics tools (fls, icat, fsstat, mmls)	Free
Volatility 3	All	Memory forensics framework	Free
exiftool	All	File/photo metadata extraction	Free
Wireshark	All	Network packet capture and analysis	Free
ADB	All	Android device access and data extraction	Free
Cellebrite UFED	Windows	Professional mobile extraction	Commercial
Magnet AXIOM	Windows	Mobile, cloud, and computer forensics	Commercial

7.2 Malware Analysis Tools

Tool	Platform	Purpose	Cost
VirusTotal	Web	Hash/sample lookup across 70+ AV engines	Free
Hybrid Analysis	Web	Online dynamic analysis sandbox	Free
ANY.RUN	Web	Interactive online malware sandbox	Free/Paid
MalwareBazaar	Web	Free malware sample repository	Free
Ghidra	All	NSA-developed decompiler/disassembler	Free

x64dbg	Windows	Windows debugger for malware	Free
FLARE VM	Windows	Malware analysis VM toolkit	Free
ProcMon	Windows	Process Monitor — file/registry/process tracking	Free
Regshot	Windows	Before/after registry comparison	Free
FakeNet-NG	Windows	Network simulation to capture C2 traffic	Free
strings	Linux	Extract readable strings from binaries	Built-in
YARA	All	Pattern matching for malware detection	Free

7.3 System Security, Hardening & Bug Hunting

Tool	Platform	Purpose	Cost
Burp Suite	All	HTTP proxy for web application testing	Free/Paid
Nikto	Linux	Web server vulnerability scanner	Free
Gobuster	Linux	Directory and file brute-forcing	Free
sqlmap	Linux	SQL injection automation	Free
OWASP ZAP	All	Web application scanner	Free
ffuf	Linux	Web fuzzer for parameters and directories	Free
Hyper-V	Windows	Windows virtualization for lab environments	Built-in
UFW	Linux	Uncomplicated Firewall for system hardening	Built-in

Section 8 — CTF Preparation Guide

8.1 CTF Categories and Strategy

CATEGORY: FORENSICS

```
file challenge # True file type
binwalk challenge # Find embedded files
binwalk -e challenge # Extract embedded files
```



```
strings challenge | grep -i "flag\|CTF"

xxd challenge | grep -i "flag"

exiftool image.jpg # Metadata

steghide extract -sf image.jpg # Steganography

zsteg image.png # PNG steganography

stegsolve # GUI steg analysis
```

CATEGORY: CRYPTOGRAPHY

```
echo "dGVzdA==" | base64 -d # Base64 decode

echo "74657374" | xxd -r -p # Hex decode

echo "Gur pngpu" | tr 'A-Za-z' 'N-ZA-Mn-za-m' # ROT13

# CyberChef "Magic" mode – detects encoding automatically

# RsaCtfTool – RSA attacks (small e, common modulus, wiener)

# hashcat / john – hash cracking
```

CATEGORY: WEB

```
# Always check source, cookies, robots.txt first

curl -v http://target/page # Verbose HTTP response

# SQL injection test

curl "http://target/page?id=1'" # Apostrophe injection test

# JWT tampering – decode at jwt.io, modify, re-sign with "none" alg

# IDOR – change user IDs in URLs and API calls
```

CATEGORY: OSINT

```
Google Dorking: site:target.com filetype:pdf "confidential"

Wayback Machine: web.archive.org – find deleted pages
```

Reverse image search: Google Images, TinEye, Yandex

Username search: Sherlock tool – checks 300+ platforms

WHOIS: whois domain.com

Shodan: search exposed services

exiftool photo.jpg – GPS coordinates in photos

CATEGORY: REVERSE ENGINEERING

```
strings binary # Readable strings (often contains the flag)
```

```
ltrace ./binary # Library calls
```

```
strace ./binary # System calls
```

```
ghidra # Open in decompiler – find main()
```

```
gdb binary # Step through with debugger
```

```
objdump -d binary | grep -A5 main # Disassemble main function
```

8.2 CTF Mindset Rules

1. **Always run file first** — challenge files often have wrong extensions
2. **Binwalk everything** — files hidden inside files is extremely common in forensics challenges
3. **Read the description carefully** — challenge authors hide hints in the text
4. **Search for the flag format first:** `strings file | grep "CTF{"` or `grep -r "flag{" ./`
5. **30-minute rule** — if stuck for 30 minutes on one approach, try something completely different
6. **Collaborate** — different people see different angles; no shame in asking teammates

Recommended Practice Platforms

Platform	URL	Best For
PicoCTF	picoctf.org	Beginner-friendly, always-on challenges
TryHackMe	tryhackme.com	Guided learning paths + CTF rooms
HackTheBox	hackthebox.com	Intermediate/advanced machines

CyberDefenders	cyberdefenders.org	Blue team and forensics focus
CTFtime	ctftime.org	Calendar of live CTF events worldwide
SANS Holiday Hack	holidayhackchallenge.com	Annual event — forensics + OSINT heavy

Section 9 — Glossary of Key Terms

Term	Definition
ADB	Android Debug Bridge — command-line tool for Android device access
Acquisition	Process of creating a forensically sound copy of digital evidence
BitMiner / Cryptominer	Malware that uses victim compute resources to mine cryptocurrency
Chain of Custody	Documentation of who handled evidence and when — required for legal admissibility
CTF	Capture The Flag — cybersecurity competition where participants solve challenges to find flags
C2	Command and Control — attacker's server that malware contacts for instructions
Dynamic Analysis	Running malware in a controlled environment to observe its behavior
E01	EnCase forensic image format — includes metadata and hash verification
Exfiltration	Unauthorized transfer of data out of a system
Faraday Bag	Signal-blocking bag that prevents wireless communication with a mobile device
FedRAMP	Federal Risk and Authorization Management Program — cloud security standard for US government
Hash	Fixed-length fingerprint of a file — used to verify integrity (SHA256, MD5)
IOC	Indicator of Compromise — artifact indicating a breach (IP, hash,

domain, etc.)

IDOR	Insecure Direct Object Reference — web vuln where changing an ID gives unauthorized access
Lateral Movement	Attacker technique of moving from one compromised system to others on the network
Logical Extraction	Backup-based mobile data acquisition — faster but misses deleted data
MITRE ATT&CK	Framework of adversary tactics and techniques used to classify attacker behavior
OSINT	Open Source Intelligence — gathering information from publicly available sources
Persistence	Attacker technique to maintain access across reboots (cron, services, registry)
Physical Extraction	Bit-for-bit copy of mobile NAND flash — most complete acquisition type
RedTail	Cryptomining malware targeting Linux servers; notable for stealth and persistence
Sandbox	Isolated environment for safely executing and observing malware
Sigma Rule	Standardized format for SIEM detection rules — like YARA for logs
SUID	Set User ID — Linux file permission allowing execution with owner privileges; abuse risk
UAC Investigation	Unauthorized Access and Compromise investigation — structured 7-step forensics process
Volatile Data	Data stored in RAM — lost when power is removed; must be captured first
Write Blocker	Hardware or software device preventing writes to evidence media during acquisition
YARA	Pattern-matching tool for identifying malware by signatures in files or memory

#	Action Item	Target	Status
1	Complete ISC2 CC study and maintain certification	Ongoing	In Progress
2	Practice USCC CTF categories on PicoCTF and CyberDefenders	Weekly	
3	Build home lab — run Autopsy, Volatility, FTK Imager on sample images	Month 1	
4	Study for CompTIA Security+ (SY0-701)	60 days	
5	Connect with Bob Costello and Balaji Subramaniam via Lou McCormack's contact share	This week	
6	Review Anthropic's report on China's use of Claude — referenced by Costello in panel	This week	
7	Create GitHub portfolio — upload YARA rules, scripts, and lab notes	Month 1	
8	Register for next CTF competition on CTFtime.org	Month 1	
9	Complete RedTail analysis walkthrough in a safe isolated VM environment	Month 1	
10	Follow Balaji's tip: learn about quantum + AI convergence via free vendor courses	Month 2	

A Note for Brandonn

You went through intensive, real-world cybersecurity training at USCC Eastern. The panelists — Bob Costello, Balaji Subramaniam, and Lou McCormack — each built their careers through persistence, curiosity, and willingness to take jobs they weren't fully qualified for. Their message was unanimous:

"Don't short-sell yourself. You are twice as good as you think you are." — Lou McCormack

The skills you built here — Linux investigation, mobile acquisition, malware triage, web exploit analysis, and CTF strategy — are the same skills used by analysts at CISA, TSA, and federal agencies every day. The foundation is built. Now go use it.

